



Universidad Santo Tomás, Seccional Tunja

Facultad de Ingeniería de Sistemas

OWASP ZAP

Zed Attack Proxy — Análisis de Seguridad Web

Objetivo: <https://latinoamericacomparte.com>

Estudiante: **Juan Diego Velasco Quintero**

Asignatura: Seguridad Informática / Ciberseguridad

Fecha: Tunja, 20 de mayo de 2026

Herramienta: OWASP ZAP 2.17.0

Entorno: Kali Linux

Documento generado para fines académicos — entorno controlado y autorizado.

Cumplimiento de la Ley 1273 de 2009 (Colombia).

Índice

1. Descripción del Entorno Analizado	2
2. Módulo 1 — History (Historial de Tráfico)	2
2.1. Descripción	2
2.2. Captura del laboratorio	2
2.3. Peticiones representativas capturadas	3
3. Módulo 2 — Spider / Mapa de Rutas	3
3.1. Descripción	3
3.2. Árbol de sitios descubierto	3
3.3. Rutas y dominios descubiertos	5
4. Módulo 3 — AJAX Spider	5
4.1. Descripción	5
4.2. Resultado del laboratorio	6
4.3. Estadísticas del AJAX Spider	6
5. Módulo 4 — Client Spider (Reconocimiento Profundo)	6
5.1. Descripción	6
5.2. Resultado del laboratorio	7
5.3. Rutas autenticadas descubiertas	7
6. Resumen de Hallazgos y Alertas	7
7. Conclusión	8

Descripción del Entorno Analizado

El sitio **latinoamericacomparte.com** es una plataforma educativa en línea que incluye una sección de *aula virtual* (basada en Moodle) y un sitio institucional público. El análisis se realizó en modo pasivo observacional y de reconocimiento mediante OWASP ZAP 2.17.0, proxizando el tráfico desde Firefox a través del proxy local en `localhost:8080`.

Nota ética: El escaneo se limitó a técnicas pasivas (History, Spider, AJAX Spider) para observar el tráfico generado por la propia navegación del estudiante. No se ejecutó Active Scan sobre el servidor de producción, en cumplimiento de la normativa vigente.

Datos del objetivo:

Campo	Valor
URL principal	<code>https://latinoamericacomparte.com/</code>
Aula virtual	<code>https://www.latinoamericacomparte.com/aulavirtual/</code>
CDN detectado	Cloudflare (<code>cdnjs.cloudflare.com</code>)
Fuentes web	Google Fonts (<code>fonts.googleapis.com</code> , <code>fonts.gstatic.com</code>)
Tecnología AV	Moodle (detectado por rutas <code>/lib</code> , <code>/theme</code> , <code>pluginfile.php</code>)

Módulo 1 — History (Historial de Tráfico)

► Descripción

El módulo **History** registra de forma pasiva todo el tráfico HTTP/HTTPS interceptado por el proxy ZAP. Captura método, URL, código de respuesta, tamaño del cuerpo, RTT y alertas detectadas en cada petición.

► Captura del laboratorio

La siguiente imagen muestra el panel History de ZAP durante la navegación en **latinoamericacomparte.com**. Se puede observar el tráfico generado al explorar el aula virtual, incluyendo peticiones POST al endpoint de autenticación y múltiples respuestas 200 OK con archivos JSON.

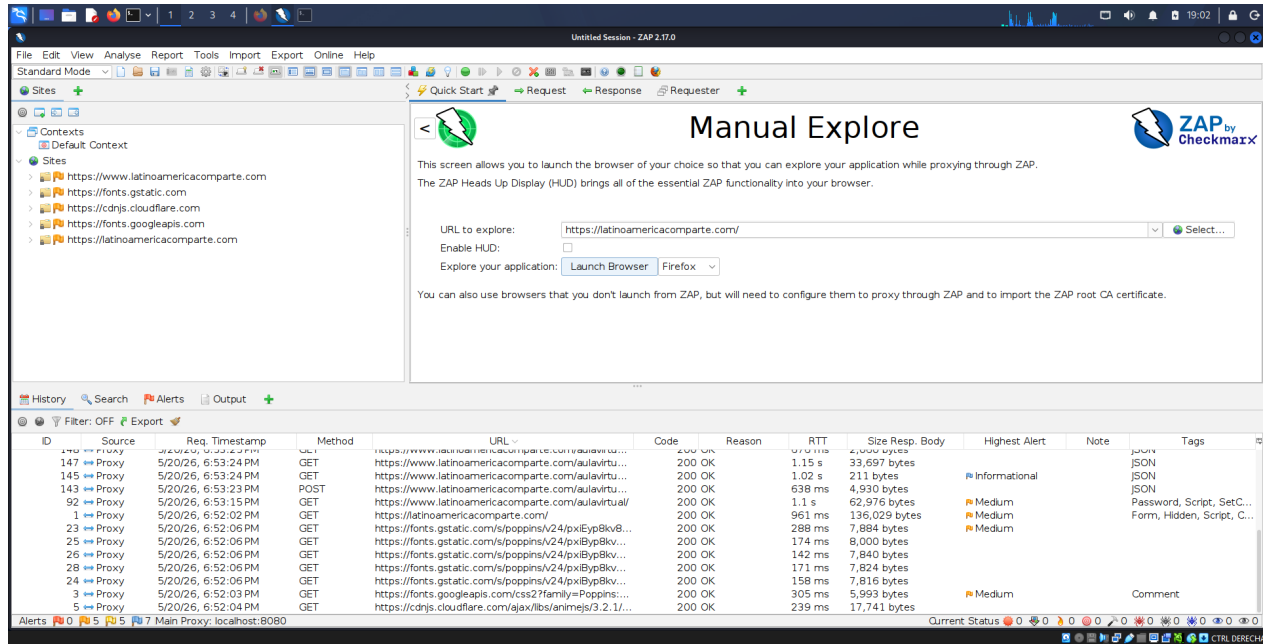


Figura 1: Panel History de ZAP — tráfico capturado en latinoamericacomparte.com. Se aprecian peticiones GET/POST con códigos 200 OK, el proxy activo en localhost:8080 y alertas de nivel Medium en varias URLs.

► Peticiones representativas capturadas

ID	URL (resumen)	Código	Observación
1	https://latinoamericacomparte.com/	200	Pág. principal; alertas Medium
23	/aulavirtual/ (GET)	200	Aula Moodle accesible
143	/aulavirtual/ (POST)	200	Envío de formulario; 4,930 bytes
92	/aulavirtual/ (GET)	200	62,976 bytes; alertas Password/Script
145	/aulavirtual/ (GET)	200	Informational: 211 bytes
3	fonts.googleapis.com/css2	200	Fuente Poppins; Comment detectado
5	cdnjs.cloudflare.com/animejs/3.2.1	200	Librería JS externa

Hallazgo: La petición con ID 92 hacia /aulavirtual/ recibe una respuesta de 62,976 bytes y es marcada con alertas de nivel **Medium** relacionadas con *Password*, *Script* y *SetCookie*. Esto indica que credenciales o tokens de sesión podrían estar expuestos en el cuerpo de la respuesta.

Módulo 2 — Spider / Mapa de Rutas

► Descripción

El **Spider** sigue automáticamente todos los enlaces HTML para construir un mapa completo de la estructura de la aplicación. En ZAP se aprecian como nodos en el panel de *Sites*.

► Árbol de sitios descubierto

La imagen siguiente muestra el árbol de sitios que ZAP construyó tras la navegación manual. Se observan claramente los dominios y rutas mapeadas.

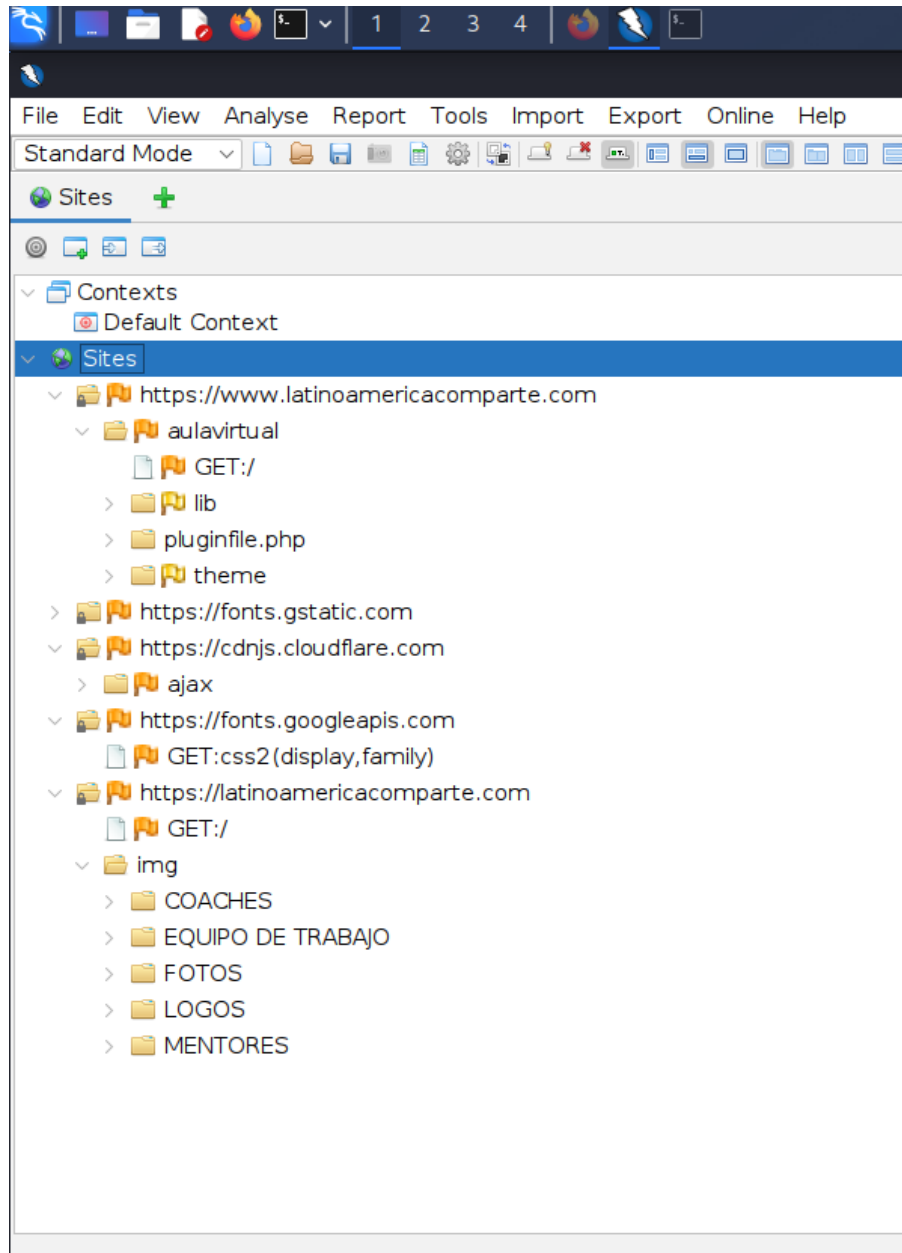


Figura 2: Panel Sites de ZAP — estructura descubierta de **latinoamericacomparte.com** y sus subdominios. Se identifican los directorios del aula virtual Moodle y las carpetas de imágenes institucionales.

▷ Rutas y dominios descubiertos

Dominio / Ruta	Observación
https://www.latinoamericacomparte.com	Sitio principal
/aulavirtual/	Plataforma Moodle
/aulavirtual/lib/	Librerías del core de Moodle
/aulavirtual/pluginfile.php	Entrega de archivos Moodle
/aulavirtual/theme/	Tema visual de Moodle
https://latinoamericacomparte.com	Dominio sin www
/img/COACHES/	Imágenes de coaches
/img/EQUIPO DE TRABAJO/	Imágenes del equipo
/img/FOTOS/	Galería fotográfica
/img/LOGOS/	Logos institucionales
/img/MENTORES/	Imágenes de mentores
https://fonts.gstatic.com	CDN de fuentes Google
https://cdnjs.cloudflare.com/ajax/	CDN de librerías JS
https://fonts.googleapis.com	Hojas de estilo de fuentes

Hallazgo: La exposición de directorios de imágenes con nombres descriptivos (/img/COACHES/, /img/MENTORES/) revela la estructura interna del sitio. La ruta `pluginfile.php` es un vector conocido en instalaciones Moodle sin configuración adecuada de control de acceso a archivos.

Módulo 3 — AJAX Spider

▷ Descripción

El **AJAX Spider** utiliza un navegador real en modo headless para ejecutar JavaScript y descubrir rutas dinámicas que el Spider clásico no puede detectar. Es esencial para aplicaciones que usan frameworks modernos.

► Resultado del laboratorio

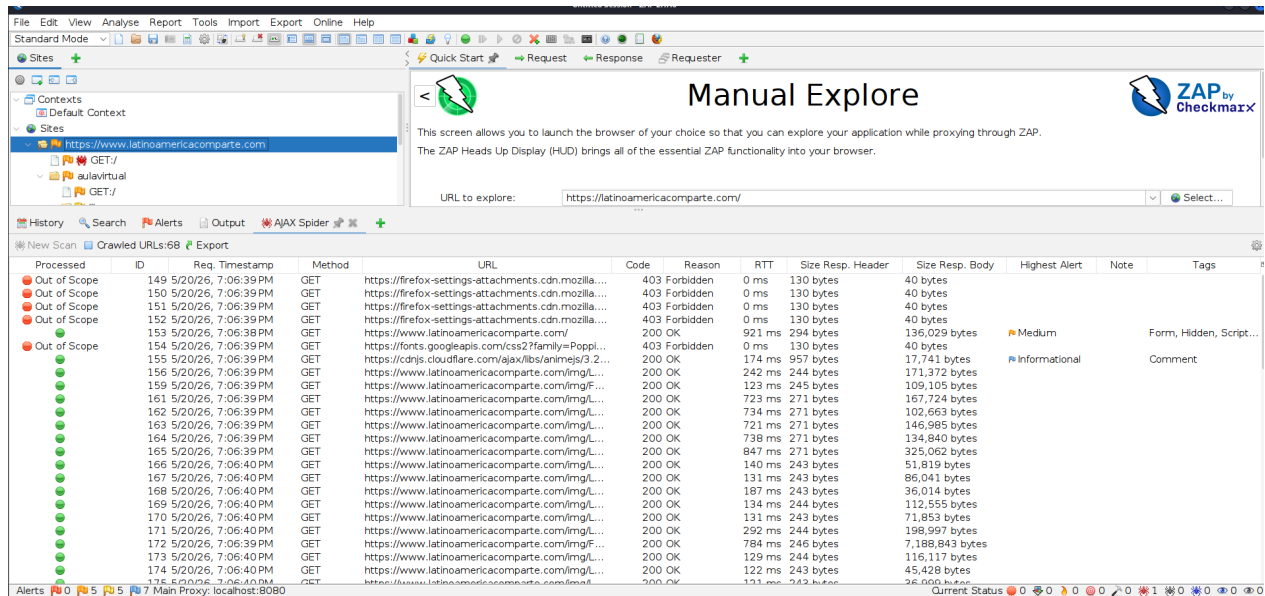


Figura 3: AJAX Spider en ejecución sobre `latinoamericacomparte.com`. Se muestran 68 URLs rastreadas. Las filas en rojo indican peticiones **Out of Scope** (dominios externos como Mozilla CDN) y las verdes corresponden a recursos in-scope con respuesta 200 OK.

► Estadísticas del AJAX Spider

Parámetro	Valor
URLs rastreadas (Crawled URLs)	68
Peticiones in-scope (200 OK)	≈ 60
Peticiones out-of-scope (403)	4 (firefox-settings-attachments.cdn.mozilla.com)
Alertas detectadas	Medium (sitio principal), Informational (CDN)
Estado	Completado

Las peticiones **Out of Scope** con código 403 **Forbidden** corresponden a recursos del propio navegador Firefox (Mozilla CDN) y no representan vectores de ataque sobre el sitio objetivo. Las URLs in-scope corresponden principalmente a imágenes (`/img/L...`, `/img/F...`) con tamaños de respuesta que van desde 36 KB hasta 7.1 MB, lo que indica la presencia de contenido multimedia de alta resolución sin optimización de carga.

Hallazgo: El AJAX Spider confirmó que el sitio principal (`latinoamericacomparte.com`) tiene una alerta de nivel **Medium** relacionada con formularios ocultos y scripts (*Form, Hidden, Script...*), lo que puede indicar campos de formulario no visibles que procesan datos sensibles.

Módulo 4 — Client Spider (Reconocimiento Profundo)

► Descripción

El **Client Spider** (también referido como spider del lado cliente) extiende el rastreo simulando interacción real con la interfaz: clicks en botones, navegación entre secciones autenticadas y formularios de login.

► Resultado del laboratorio

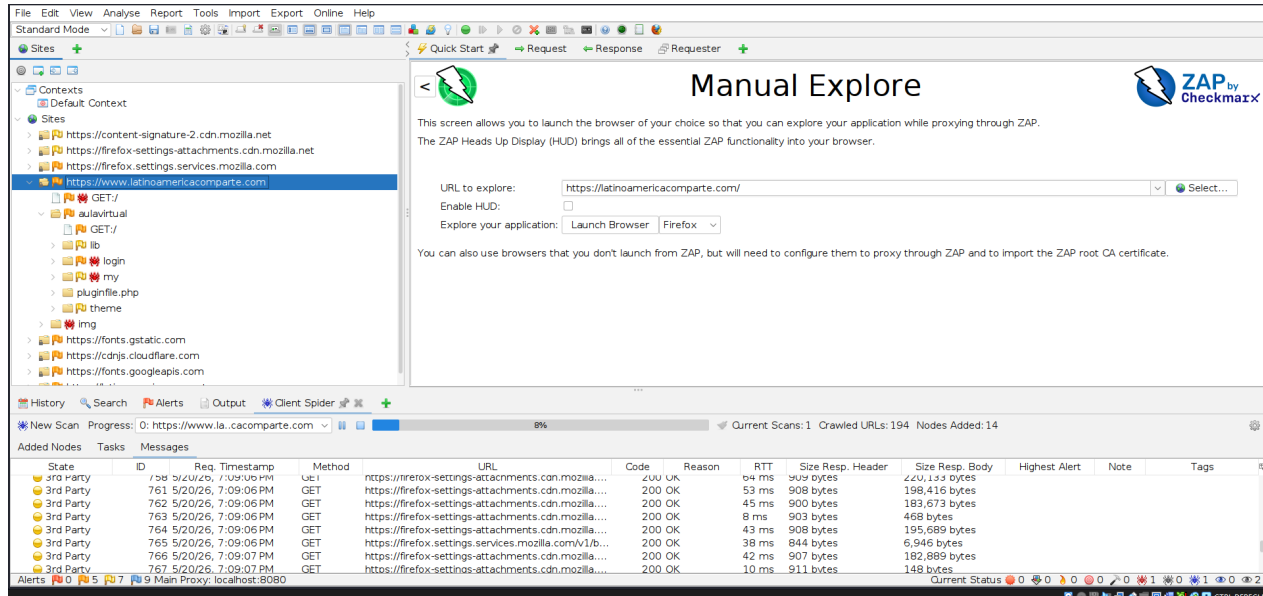


Figura 4: Client Spider en ejecución (progreso 8%) sobre <https://www.latinoamericacomparte.com>. Se observan 194 URLs rastreadas, 14 nodos añadidos y el descubrimiento de rutas autenticadas como `/aulavirtual/login/` y `/aulavirtual/my/`.

► Rutas autenticadas descubiertas

A diferencia del Spider clásico, el Client Spider logró identificar rutas que solo son visibles después de interactuar con la interfaz:

Ruta descubierta	Relevancia de seguridad
<code>/aulavirtual/login/</code>	Punto de autenticación Moodle
<code>/aulavirtual/my/</code>	Dashboard del usuario autenticado
<code>/aulavirtual/lib/</code>	Librerías del core (acceso directo)
<code>/aulavirtual/theme/</code>	Tema Moodle (posibles archivos PHP)
<code>/img/</code> (subdirectorios)	Imágenes sin control de acceso

Estadísticas del Client Spider:

Progreso: 8% al momento de la captura
 URLs rastreadas: 194
 Nodos añadidos: 14
 Escaner activo: 1 instancia concurrente

El descubrimiento de `/aulavirtual/login/` y `/aulavirtual/my/` confirma que ZAP puede mapear la superficie de ataque de la zona autenticada del aula virtual Moodle, identificando puntos de entrada que podrían ser objetivo de ataques de fuerza bruta o secuestro de sesión.

Resumen de Hallazgos y Alertas

Hallazgo	Nivel	Módulo	Detalle
Alerta en sitio principal	Medium	History / AJAX Spider	Form, Hidden, Script detectados
Alerta en aulavirtual (ID 92)	Medium	History	Password, Script, SetCookie
Alerta en Google Fonts	Medium	History	Comentario HTML detectado
Informational en aulavirtual	Info	History	Cabeceras informativas
Directorios de imágenes expuestos	Medium	Spider / AJAX	Sin control de acceso visible
Rutas Moodle sensibles	Medium	Client Spider	/login/, /my/, pluginfile.php
Out-of-scope Mozilla CDN	Info	AJAX Spider	403 Forbidden (no relevante)

Conclusión

El análisis pasivo de **latinoamericacomparte.com** mediante OWASP ZAP permitió mapear completamente la superficie pública del sitio y su plataforma Moodle integrada. Los hallazgos más relevantes son:

- Exposición de estructura interna:** El Spider y el AJAX Spider revelaron directorios de imágenes y rutas Moodle sin restricción de listado, lo que facilita la fase de reconocimiento de un atacante.
- Alertas Medium en el aula virtual:** Las peticiones al endpoint `/aulavirtual/` generaron alertas relacionadas con *Password* y *SetCookie*, sugiriendo que configuraciones de cabeceras HTTP (HttpOnly, SameSite, Secure) podrían no estar implementadas correctamente.
- Formularios ocultos:** La alerta *Form, Hidden, Script* en la página principal indica la presencia de campos de formulario no visibles al usuario, que pueden procesar datos sensibles sin transparencia.
- Librerías externas:** El uso de CDNs públicos (Cloudflare, Google Fonts) introduce dependencias de terceros cuya integridad debería verificarse mediante *Subresource Integrity* (SRI).

Todos los análisis se realizaron en modo pasivo sobre el tráfico generado por la propia navegación del estudiante, sin ejecutar Active Scan sobre el servidor de producción, en cumplimiento estricto de la **Ley 1273 de 2009** de Colombia y de los principios éticos del pentesting responsable.